Introduktion til software sikkerhed Del 4

Del 4 – Risikovurdering og styring.

Af Martin Edwin Schjødt Nielsen

University College

Risikostyring og vurdering.

De fleste virksomheder foretager risikovurderinger af en eller anden art. For eksempel udføres der økonomiske risikovurderinger, inden der træffes beslutninger om nye investeringer. Ligeledes bør der laves risikovurderinger af de IT-systemer, der understøtter forretningen.

Risikovurderingen tager udgangspunkt i de misbrugstilfælde, der definerer sikkerhedsmålene. Hvert enkelt misbrugstilfælde indebærer konsekvenser for forretningen, herunder økonomiske konsekvenser. For eksempel omkostningerne ved, at et eller flere systemmål ikke længere kan opfyldes. Et konkret eksempel kunne være tabt omsætning for en webshop, hvis denne ikke er i stand til at sælge sine varer i 8 timer. I risikovurderingen tages der udgangspunkt i misbrugstilfældene. Her vil man så bruge formelen Konsekvens * Sandsynlighed til at vurdere risikoen ved hvert misbrugstilfælde.

Sikkerhedsstandarden ISO 27005 opdeler risikostyring i 5 trin, som vist i Figur 1



Figur 1 De 5 trin i risikostyringsprocessen

I de følgende afsnit vil hvert trin blive gennemgået, i kontekst til sikker softwareudvikling.

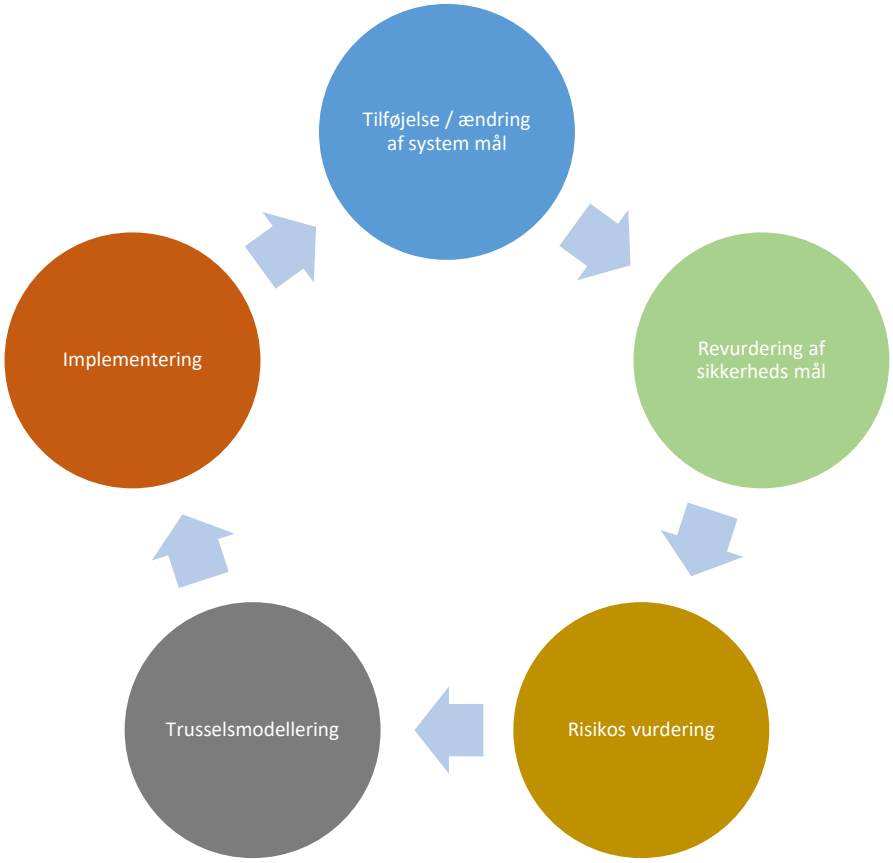
Etablering af kontekst

Formålet med etablering af kontekst er at fastsætte rammerne for risikostyring. Her bør følgende punkter afdækkes:

- Hvad er systemets kontekst?
- Hvilken dele af forretningen understøtter systemet?
- Hvem er interessenterne?
- Hvad er aktiverne?
- Hvem er ejerne af aktiverne?
- Valg af metode.

De første 5 punkter bør være afdækket i udarbejdelsen af brugs og-misbrugstilfælde.

Punktet metode valg indebærer at man fastslår den løbende proces for risikovurdering og hvordan risici analysen udføres. Den løbende proces som kan anvendes, uddybes i del 6 af serien. Overordnet proces ser ud som vist i figur 2.



Figur 2 Den overordnet proces for risikostyring og vurdering

Sikkerhedsmål skaber input til risikostyring og vurdering. De misbrugstilfælde, som er blevet identificeret som sikkerhedsmål, bliver analyseret i risikostyring og vurdering og danner grundlag for prioritering af trusler i trusselsmodellering (uddybes i del 5). Dette er en løbende og iterativ proces.

Den anden del af metodevalget handler om, hvordan en risikoanalyse udføres. Typisk anvendes formelen Risiko = Konsekvens * Sandsynlighed, hvor konsekvens er omkostningerne for forretningen, hvis systemet misbruges. Sandsynlighed er en vurdering af, hvor sandsynligt det er, at systemet misbruges. F.eks. når man skal vurdere risiko og sandsynlighed, kan man bruge en kvalitativ tilgang eller en kvantitativ tilgang. Den kvalitative tilgang bliver uddybet i afsnittet om analyse af risici. Den kvantitative tilgang behandles ikke i dette dokument.

Identifikation af risici

Risici identificeres primært som misbrugstilfælde i arbejdet med sikkerhedsmål og udgør input til risikostyring og -vurdering. Disse misbrugstilfælde prioriteres derefter baseret på risikoanalysen i risikostyring og skaber input til trusselsmodellering, hvor tekniske risici identificeres og formuleres som konkrete sikkerhedskrav. Det anbefales, at hvert misbrugstilfælde indledningsvist gennemgår en risikovurdering.

Analyse af risici

Når man skal udføre en risiko analyse benyttes formelen *Risiko=Konsekvens*Sandsynlighed.*

Der er to tilgange, man kan vælge: en kvalitativ eller en kvantitativ tilgang. Som udgangspunkt er den kvalitative tilgang den mest enkle. Man opretter en skala for både konsekvens og sandsynlighed, hvor hvert trin er defineret. For eksempel kan man bruge en skala med værdierne 1–5 for konsekvens, hvor 1 er ubetydeligt, og 5 er katastrofalt, som vist i Figur 3

Skala for konsekvens
1- Ubetydeligt
2 – Begrænset
3 – Alvorligt
4 – Farligt
5- Katastrofalt

Figur 3 Skala for konsekvens

Ligeledes kan man lave en for en skala for sandsynlighed som vist i Figur 4

Skala for sandsynlighed
1- Usandsynligt
2 – Sjældent
3 – Muligt
4 – Sandsynligt
5- Næsten sikkert

Figur 4 Skala for sandsynlighed

Når skalaerne er etableret, kan man udføre en risikovurdering ved at vurdere både risiko og konsekvens. For eksempel, hvis tilfældet er, at misbrugstilfældet ikke vil have nogen påvirkning på forretningen, men sandsynligheden for, at dette sker, er næsten sikkert, kan man opstille ligningen Risiko = 1 * 5 = 5. Havde konsekvensen derimod været katastrofal, ville ligningen have set således ud: Risiko = 5 * 5 = 25.

Desto højere værdi en risiko har, desto højere bør den prioriteres. Typisk udarbejdes der et risiko matrix for at definere risiko værdier (Produktet af hver risiko beregning). Som vist i Figur 5

		Konsekvens				
Sandsynlighed		1 Ubetydeligt	2 Begrænset	3 Alvorligt	4 Farligt	5 Katastrofal
	5 Næsten sikkert	5 Moderat	10 Høj	15 Meget Høj	20 Meget Høj	25 Meget Høj
	4 Sandsynligt	4 Moderat	8 Høj	12 Høj	16 Meget Høj	20 Meget Høj
	3 Muligt	3 Lav	6 Moderat	9 Høj	12 Høj	15 Meget Høj
	2 Sjældent	2 Lav	4 Moderat	6 Moderat	8 Høj	10 Høj
	1 Usandsynligt	1 Lav	2 Lav	3 Lav	4 Moderat	5 Moderat

Figur 5 Risikomatrix

Evaluering af risici

I dette trin skal risikoerne evalueres. Dette betyder, at hver enkelt risiko skal vurderes i forhold til, om det er en risiko, der skal prioriteres og håndteres, eller om den kan vente til et senere tidspunkt. Hvis man vælger ikke at sende en risiko videre til håndtering, kaldes dette en accepteret risiko. Altså, der er kendskab til risikoen, men man vælger aktivt ikke at gøre noget ved den. Dette kan være på grund af ressourcemangel eller fordi risikoen hverken kan undgås eller minimeres.

Et alternativ til at acceptere en risiko kan være at fjerne et systemmål. Altså, hvis risikoen er for høj, skal systemet ikke længere understøtte dette forretningsmål. Typisk er det ledelsen, som har overblikket og autoriteten i forhold til risikovillighed, og derfor bør det være ledelsen, der træffer disse beslutninger.

Håndtering af risici

Når alle risikoer er fastslået og prioriteret. Skal de håndteres. Typisk bør man overveje følgende to punkter

- Kan risikoen overføres?
- Kan risikoen minimeres?

Med punkt 1 menes der om man kan få andre til at påtage sig risikoen. Dette kan være ved at outsource håndtering af systemmålet som skaber risikoen, eller ved at eliminerer konsekvenserne (F.eks. via en forsikring).

Minimering af risikoer kræver typisk en teknisk foranstaltning. Fremgangsmåden til dette beskrives i Del 5 - trusselsmodellering.